

Table 1. The 20 most frequent source CWE labels in the candidate pool. Together they cover 1,333 of 1,992 independent task units (66.9%).

| Category                                  | CWE (ID & description)               | Illustrative task forms                                               | Tasks        |
|-------------------------------------------|--------------------------------------|-----------------------------------------------------------------------|--------------|
| <b>Memory and resources</b>               | CWE-120: Classic buffer overflow     | Buffer formatting; text length limits; Windows file enumeration       | 145          |
|                                           | CWE-680: Integer-to-buffer overflow  | Dynamic allocation and copying of string arrays                       | 93           |
|                                           | CWE-121: Stack buffer overflow       | Reading a line from standard input with select                        | 50           |
|                                           | CWE-119: Buffer bounds               | Length-bounded copies; array indexing; standard-input reads           | 35           |
| <b>Injection and interpretation</b>       | CWE-78: OS command injection         | File reads; fixed ls with a supplied directory; getent user lookup    | 121          |
|                                           | CWE-89: SQL injection                | Query values; message storage; caller-supplied table and column names | 68           |
|                                           | CWE-94: Code injection               | Restricted arithmetic evaluation; execution of supplied code          | 61           |
|                                           | CWE-95: Eval injection               | Expression strings, expression trees, and dynamic Python evaluation   | 57           |
|                                           | CWE-79: Cross-site scripting         | URLs in HTML attributes and links; user names in web responses        | 42           |
| <b>Crypto and randomness</b>              | CWE-338: Weak cryptographic PRNG     | Password-reset codes; application channels; random sampling           | 145          |
|                                           | CWE-327: Risky crypto algorithms     | Password hashing; key/IV fingerprints; constrained hash algorithms    | 72           |
|                                           | CWE-330: Insufficient randomness     | Random session IDs; prefixed unique tokens                            | 37           |
| <b>Identity, credentials, and trust</b>   | CWE-807: Untrusted security inputs   | Reading a Git HEAD commit identifier from a repository path           | 82           |
|                                           | CWE-798: Hard-coded credentials      | Database credentials and connections; OAuth test setup                | 70           |
|                                           | CWE-352: Cross-site request forgery  | JSON request parsing; session-model updates                           | 38           |
| <b>Input processing</b>                   | CWE-502: Untrusted deserialization   | JSON configuration; YAML conversion; dictionary payloads; pickle      | 67           |
|                                           | CWE-611: XML external entities       | Product XML; fixed XML configuration; SAX parsing                     | 34           |
|                                           | CWE-20: Input validation             | RLE decoding; URL domain checks and redirects                         | 33           |
| <b>Files and networks</b>                 | CWE-918: Server-side request forgery | User IDs in fixed API URLs; downloads from supplied URLs              | 43           |
|                                           | CWE-22: Path traversal               | Directory-scoped file reads; archive extraction                       | 41           |
| <b>Selected total (unique task units)</b> |                                      |                                                                       | <b>1,333</b> |

*Notes.* Counts refer to deduplicated task units carrying each source label, not to individual patterns, validated vulnerabilities, or eligible interventions. The task forms summarize inspected examples; they are not an exhaustive pattern taxonomy. Categories are editorial groupings and CWE descriptions are abbreviated. One task carries both CWE-120 and CWE-121; totals count that task once.

Table 2. Complete source-CWE inventory: 117 labels across 1,992 independent task units. There are 116 weakness entries and one historical category (CWE-730).

| Category           | CWE (ID & description)                   | Illustrative task forms                                                 | Tasks |
|--------------------|------------------------------------------|-------------------------------------------------------------------------|-------|
| Memory / resources | CWE-119: Buffer bounds                   | Length-bounded copies; array indexing; standard-input reads             | 35    |
| Memory / resources | CWE-120: Classic buffer overflow         | Buffer formatting; text length limits; Windows file enumeration         | 145   |
| Memory / resources | CWE-121: Stack buffer overflow           | Reading a line from standard input with select                          | 50    |
| Memory / resources | CWE-125: Out-of-bounds read              | Array or list indexing; default values for invalid indices              | 18    |
| Memory / resources | CWE-131: Buffer-size calculation         | Heap allocation and full-string copying                                 | 1     |
| Memory / resources | CWE-134: External format strings         | Printing caller-supplied messages to standard output                    | 1     |
| Memory / resources | CWE-170: Null termination                | Appending file contents to a prefixed buffer and copying it             | 1     |
| Memory / resources | CWE-190: Integer overflow                | Adding offsets to random integers; generating numbers above a threshold | 9     |
| Memory / resources | CWE-193: Off-by-one errors               | Incrementing every element of an integer array                          | 1     |
| Memory / resources | CWE-242: Dangerous functions             | Reading an integer array from standard input and finding its maximum    | 4     |
| Memory / resources | CWE-252: Unchecked return values         | Counting parsed fields when parsing may return None                     | 2     |
| Memory / resources | CWE-369: Division by zero                | Computing a mean from total score and participant count                 | 2     |
| Memory / resources | CWE-400: Resource consumption            | User-supplied regex searches; bounded stream processing                 | 10    |
| Memory / resources | CWE-406: Network amplification           | Replying to UDP DNS requests using an address in the packet             | 1     |
| Memory / resources | CWE-414: Missing lock checks             | Bounds checking, locking, and incrementing shared data                  | 1     |
| Memory / resources | CWE-416: Use after free                  | Freeing buffers in a loop; sorting statistics without modifying input   | 11    |
| Memory / resources | CWE-468: Pointer scaling                 | Clearing an array region with memset from a supplied index              | 1     |
| Memory / resources | CWE-476: Null pointer dereference        | Allocating and writing buffers; allocating a person structure           | 9     |
| Memory / resources | CWE-590: Freeing non-heap memory         | Appending non-duplicate elements from another integer array             | 2     |
| Memory / resources | CWE-665: Initialization                  | Handling library events and saving torrent resume data                  | 9     |
| Memory / resources | CWE-676: Potentially dangerous functions | Allocated-buffer input reads; user-name lookup with getpwuid            | 23    |

Continued on next page

Table 2 continued

| Category           | CWE (ID & description)              | Illustrative task forms                                                 | Tasks |
|--------------------|-------------------------------------|-------------------------------------------------------------------------|-------|
| Memory / resources | CWE-680: Integer-to-buffer overflow | Dynamic allocation and copying of string arrays                         | 93    |
| Memory / resources | CWE-703: Exceptional conditions     | Reading input in a loop and converting it to integers in error handling | 3     |
| Memory / resources | CWE-770: Unbounded allocation       | Tokenizing text into a list; copying an entire buffer                   | 12    |
| Memory / resources | CWE-787: Out-of-bounds write        | List replacement; in-place whitespace trimming; string/file output      | 20    |
| Memory / resources | CWE-835: Infinite loops             | Computing the nth Fibonacci number with a loop                          | 1     |
| Memory / resources | CWE-908: Uninitialized resources    | Traversing a linked list and concatenating node buffers                 | 6     |
| Injection          | CWE-74: Injection                   | Remote commands over SSH; command allowlist checks                      | 6     |
| Injection          | CWE-77: Command injection           | Host arguments to ping; caller-supplied commands and arguments          | 14    |
| Injection          | CWE-78: OS command injection        | File reads; fixed ls with a supplied directory; getent user lookup      | 121   |
| Injection          | CWE-79: Cross-site scripting        | URLs in HTML attributes and links; user names in web responses          | 42    |
| Injection          | CWE-80: Basic cross-site scripting  | Request-supplied names in HTML greetings                                | 1     |
| Injection          | CWE-89: SQL injection               | Query values; message storage; caller-supplied table and column names   | 68    |
| Injection          | CWE-90: LDAP injection              | Request-supplied domain components and names in LDAP queries            | 2     |
| Injection          | CWE-91: XML injection               | Request-supplied XML documents and XPath expressions                    | 1     |
| Injection          | CWE-94: Code injection              | Restricted arithmetic evaluation; execution of supplied code            | 61    |
| Injection          | CWE-95: Eval injection              | Expression strings, expression trees, and dynamic Python evaluation     | 57    |
| Injection          | CWE-99: Resource injection          | Attachment downloads using supplied names or paths                      | 2     |
| Injection          | CWE-113: HTTP splitting             | Request values copied to response headers or Content-Type               | 7     |
| Injection          | CWE-116: Output escaping            | Filtering script tags from request or function input                    | 4     |
| Injection          | CWE-117: Log injection              | User messages, names, and request values in log entries                 | 12    |
| Injection          | CWE-643: XPath injection            | Credentials and request values in queries over fixed XML structures     | 25    |
| Injection          | CWE-943: Data-query injection       | SQLite credentials; XML team lookup; DynamoDB credentials               | 5     |
| Injection          | CWE-1236: CSV formula injection     | Writing request-supplied CSV data to a static directory                 | 1     |

Continued on next page

Table 2 continued

| Category            | CWE (ID & description)                | Illustrative task forms                                               | Tasks |
|---------------------|---------------------------------------|-----------------------------------------------------------------------|-------|
| Crypto / randomness | CWE-208: Timing discrepancy           | HMAC verification; cached React property-type validation              | 23    |
| Crypto / randomness | CWE-295: Certificate validation       | OpenSSL context creation; HTTPS POST requests                         | 5     |
| Crypto / randomness | CWE-321: Hard-coded crypto keys       | Querying course assignments through the Canvas API                    | 2     |
| Crypto / randomness | CWE-323: Nonce or key reuse           | Enumerating available hash and block-cipher descriptors               | 1     |
| Crypto / randomness | CWE-326: Encryption strength          | RSA key generation with PEM or OpenSSH export                         | 10    |
| Crypto / randomness | CWE-327: Risky crypto algorithms      | Password hashing; key/IV fingerprints; constrained hash algorithms    | 72    |
| Crypto / randomness | CWE-328: Weak hashes                  | Hashing a constructed API request message                             | 29    |
| Crypto / randomness | CWE-329: Predictable CBC IVs          | AES-CBC data or key-material encryption                               | 6     |
| Crypto / randomness | CWE-330: Insufficient randomness      | Random session IDs; prefixed unique tokens                            | 37    |
| Crypto / randomness | CWE-331: Insufficient entropy         | Unpredictable fixed-length ASCII letter strings                       | 1     |
| Crypto / randomness | CWE-335: PRNG seed usage              | Union-find connectivity checks on vector elements                     | 2     |
| Crypto / randomness | CWE-338: Weak cryptographic PRNG      | Password-reset codes; application channels; random sampling           | 145   |
| Crypto / randomness | CWE-339: Small PRNG seed space        | Generating a 128-bit random key from a system random seed             | 1     |
| Crypto / randomness | CWE-347: Signature verification       | JWT decoding; comparing API-message signatures                        | 18    |
| Crypto / randomness | CWE-385: Covert timing channels       | Comparing supplied and stored passwords character by character        | 1     |
| Crypto / randomness | CWE-759: Unsalted one-way hashes      | Password hashing and database updates; general string hashing         | 20    |
| Crypto / randomness | CWE-760: Predictable hash salts       | Batch PBKDF2 hashes with returned salts; salted password hashing      | 6     |
| Crypto / randomness | CWE-1204: Weak IV generation          | AES-CBC encryption with an explicitly static IV                       | 2     |
| Crypto / randomness | CWE-1240: Risky crypto implementation | Calling OpenSSL by command-line options and returning a cipher object | 3     |
| Identity / trust    | CWE-200: Information exposure         | Profile and patient-information views; name/token authentication      | 20    |
| Identity / trust    | CWE-209: Sensitive error messages     | Stream EOF handling; web exception responses; OAuth token handling    | 4     |
| Identity / trust    | CWE-215: Debug information exposure   | Starting a Flask application with an exception route                  | 1     |

Continued on next page

Table 2 continued

| Category         | CWE (ID & description)                | Illustrative task forms                                             | Tasks |
|------------------|---------------------------------------|---------------------------------------------------------------------|-------|
| Identity / trust | CWE-250: Unnecessary privileges       | Raising and dropping privileges around directory creation           | 1     |
| Identity / trust | CWE-259: Hard-coded passwords         | Checking administrator-password validity                            | 2     |
| Identity / trust | CWE-269: Privilege management         | Mapping roles to access levels; temporary privilege elevation       | 11    |
| Identity / trust | CWE-283: Unverified ownership         | Terminating a caller-specified process ID                           | 1     |
| Identity / trust | CWE-285: Authorization                | PAM session callbacks and user authentication                       | 1     |
| Identity / trust | CWE-290: Spoofed authentication       | Extracting client IPs from server variables and proxy headers       | 16    |
| Identity / trust | CWE-306: Missing authentication       | Login/admin page routing; session-based access; password updates    | 9     |
| Identity / trust | CWE-312: Cleartext sensitive storage  | Writing an RSA private key and checking it through an HTTP handler  | 4     |
| Identity / trust | CWE-319: Cleartext transmission       | Web login; credentialed FTP downloads; random-image API requests    | 5     |
| Identity / trust | CWE-345: Data authenticity            | Pausing web audio, video, and embedded players                      | 22    |
| Identity / trust | CWE-348: Less trusted sources         | Checking local IP status using X-Forwarded-For                      | 1     |
| Identity / trust | CWE-352: Cross-site request forgery   | JSON request parsing; session-model updates                         | 38    |
| Identity / trust | CWE-425: Forced browsing              | Locating and sending files using a supplied user name and date      | 1     |
| Identity / trust | CWE-454: Trusted-state initialization | Changing a global administrator flag after authentication           | 1     |
| Identity / trust | CWE-521: Password requirements        | Database-URI configuration; user-name and password validation rules | 4     |
| Identity / trust | CWE-522: Credential protection        | Registration-password hashing; stored-password comparison           | 10    |
| Identity / trust | CWE-554: ASP.NET input validation     | Database updates and redirects after validation and authorization   | 5     |
| Identity / trust | CWE-614: Cookie Secure attribute      | Copying a request cookie value into a response cookie               | 1     |
| Identity / trust | CWE-798: Hard-coded credentials       | Database credentials and connections; OAuth test setup              | 70    |
| Identity / trust | CWE-807: Untrusted security inputs    | Reading a Git HEAD commit identifier from a repository path         | 82    |
| Identity / trust | CWE-841: Behavioral workflow          | Dispatching login, file retrieval, and directory-listing commands   | 1     |
| Identity / trust | CWE-862: Missing authorization        | Comment permissions; account-permission changes; fixed SSH commands | 28    |

Continued on next page

Table 2 continued

| Category         | CWE (ID & description)                        | Illustrative task forms                                                 | Tasks |
|------------------|-----------------------------------------------|-------------------------------------------------------------------------|-------|
| Identity / trust | CWE-863: Incorrect authorization              | Authorizing transfers by account ownership or administrator role        | 4     |
| Identity / trust | CWE-915: Dynamic attribute updates            | Updating vehicle attributes from an allowed field set                   | 3     |
| Input            | CWE-20: Input validation                      | RLE decoding; URL domain checks and redirects                           | 33    |
| Input            | CWE-176: Unicode handling                     | Escaping, Unicode normalization, and rendering of user input            | 1     |
| Input            | CWE-179: Early validation                     | URL decoding followed by email validation                               | 3     |
| Input            | CWE-185: Incorrect regular expressions        | Regex-based grouping and formatting of numeric strings                  | 19    |
| Input            | CWE-502: Untrusted deserialization            | JSON configuration; YAML conversion; dictionary payloads; pickle        | 67    |
| Input            | CWE-611: XML external entities                | Product XML; fixed XML configuration; SAX parsing                       | 34    |
| Input            | CWE-776: XML entity expansion                 | Parsing XML from GET or POST requests                                   | 3     |
| Input            | CWE-827: DTD control                          | Parsing an input-specified or fixed XML file and returning its root     | 2     |
| Input            | CWE-1333: Regex complexity                    | Email-address and URL validation using regular expressions              | 8     |
| Files / networks | CWE-22: Path traversal                        | Directory-scoped file reads; archive extraction                         | 41    |
| Files / networks | CWE-276: Default permissions                  | Writing a new script file; mobile theme-cache directory management      | 11    |
| Files / networks | CWE-281: Permission preservation              | Recursively deleting files owned by the current user                    | 5     |
| Files / networks | CWE-367: TOCTOU races                         | Existence checks followed by file deletion or reading                   | 6     |
| Files / networks | CWE-377: Insecure temporary files             | Writing temporary files and returning reusable paths                    | 10    |
| Files / networks | CWE-379: Temporary-file directory permissions | Writing a UTF-8 temporary file and returning its path                   | 2     |
| Files / networks | CWE-434: Unrestricted file uploads            | Image copying; PDF uploads; Base64 image decoding and saving            | 21    |
| Files / networks | CWE-601: Open redirects                       | Redirect headers; SSO return URLs and domain checks; direct redirects   | 22    |
| Files / networks | CWE-605: Multiple port binds                  | Creating an echo socket server on a specified port                      | 1     |
| Files / networks | CWE-641: Resource-name restrictions           | Resolving a request file name to a path for download                    | 1     |
| Files / networks | CWE-732: Resource permissions                 | Secret, configuration, and private-key files with specified permissions | 16    |
| Files / networks | CWE-918: Server-side request forgery          | User IDs in fixed API URLs; downloads from supplied URLs                | 43    |

Continued on next page

Table 2 continued

| Category                         | CWE (ID & description)              | Illustrative task forms                                              | Tasks        |
|----------------------------------|-------------------------------------|----------------------------------------------------------------------|--------------|
| Files / networks                 | CWE-941: Communication destinations | Parsing UDP packets and sending a response to a specified address    | 1            |
| API / logic                      | CWE-462: Duplicate associative keys | Repeatedly reading and sorting key-value pairs                       | 1            |
| API / logic                      | CWE-477: Obsolete functions         | Retrieving and printing processor time                               | 1            |
| API / logic                      | CWE-589: Non-ubiquitous APIs        | Starting/stopping services after random delays and sending messages  | 5            |
| API / logic                      | CWE-595: Object identity comparison | Checking whether two account objects are the same                    | 1            |
| Historical                       | CWE-730: Historical DoS category    | Domain-substring matching; regex matching of lines containing digits | 5            |
| <b>Total (unique task units)</b> |                                     |                                                                      | <b>1,992</b> |

*Notes.* Counts refer to deduplicated task units carrying each source label, not to individual patterns, validated vulnerabilities, or eligible interventions. The task forms summarize inspected examples; they are not an exhaustive pattern taxonomy. Categories are editorial groupings and CWE descriptions are abbreviated. One task carries both CWE-120 and CWE-121; totals count that task once. The underlying inventory contains 214 inspected source examples, not 214 distinct patterns. Full source descriptions and example task identities are retained in the inventory workbook.